PÓS-GRADUAÇÃO · CYBERSECURITY

Segurança em Nuvem e *DevSecOps*

Arquitetura de defesa, automação de esteira e resiliência

Módulo Avançado de Segurança em Sistemas Distribuídos e Cloud Native

Semestre Letivo 2026 · Aula Técnica 02 · 120 minutos



DOCENTE

Prof. Cloves Rocha

PROGRAMA

Pós-Graduação em **Cybersecurity**

Made with GAMMA

FUNDAMENTOS

Shared Responsibility

MODELO

Segurança na nuvem começa na responsabilidade compartilhada

1 **Segurança DA Nuvem (Provedor)**

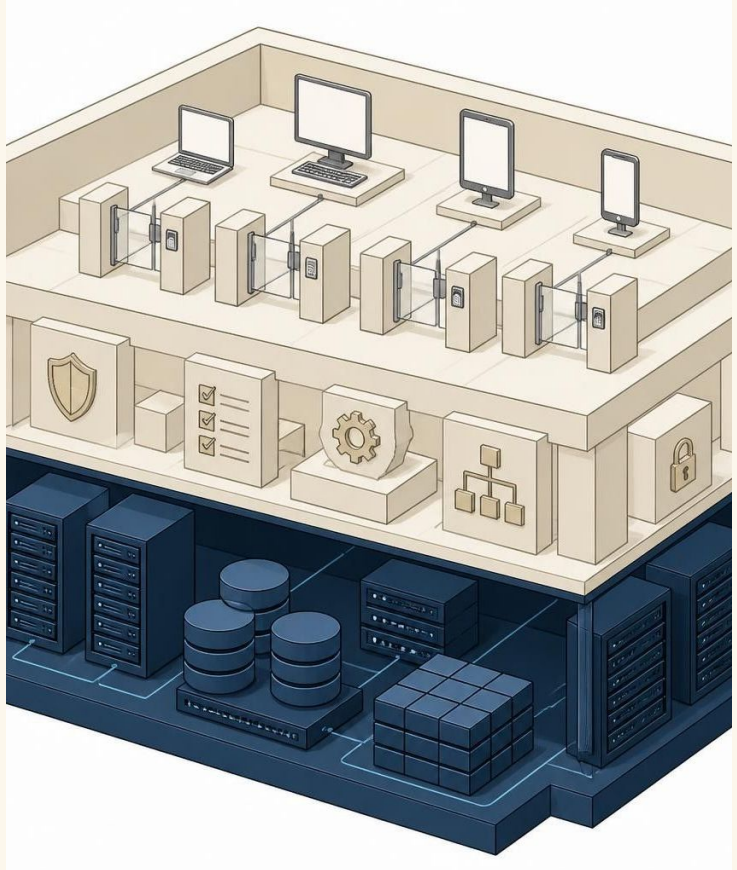
Proteção de data centers físicos, hipervisores, hardware e isolamento elétrico e de rede global.

2 **Segurança NA Nuvem (Cliente)**

Identidades, permissões IAM, dados em repouso, políticas de rede e configurações dos recursos.

3 **Vetor Crítico: Má Configuração**

Mais de 80% dos incidentes corporativos decorrem de falhas operacionais do próprio cliente.



Aula Técnica 02

Made with GAMMA

ECOSSISTEMA

Multi-Cloud Matriz

COMPARATIVO

AWS, Azure e GCP: mesmos riscos, serviços diferentes

Mapeamento direto de capacidades essenciais entre os principais provedores de hiperescala:

DOMÍNIO DE RISCO	AMAZON WEB SERVICES	MICROSOFT AZURE	GOOGLE CLOUD PLATFORM
Identidade & Acesso	AWS IAM & IAM Identity Center	Microsoft Entra ID (Azure AD)	Google Cloud IAM & Workforce
Trilhas & Detecção	CloudTrail & GuardDuty	Azure Monitor & Defender for Cloud	Cloud Audit Logs & Security Command Center
Chaves & Segredos	AWS KMS & Secrets Manager	Azure Key Vault & Managed HSM	Cloud KMS & Secret Manager
Postura de Segurança	AWS Security Hub	Defender CSPM	Security Command Center Premium

Princípio: arquiteturas multi-cloud padronizam a taxonomia de controles, não o ferramental nativo.

AWS · Azure · GCP

Made with GAMMA

BASELINE

Hardening Cloud

PILARES

CIS Benchmarks

Hardening na nuvem: menor privilégio, rede e criptografia

PILAR 01

Menor Privilégio

Eliminação estrita de políticas wildcard (*), imposição inegociável de MFA e credenciais de curta duração via federation/STS.

PILAR 02

Perímetro & Rede

VPCs segmentadas, Security Groups sem 0.0.0.0/0 para portas de gerência e bloqueio público em buckets S3/Storage.

PILAR 03

Criptografia

TLS 1.3 obrigatório em trânsito com ALPN restrito; envelopes KMS gerenciados pelo cliente (CMEK) em repouso nos discos e bancos.

PILAR 04

Auditoria Contínua

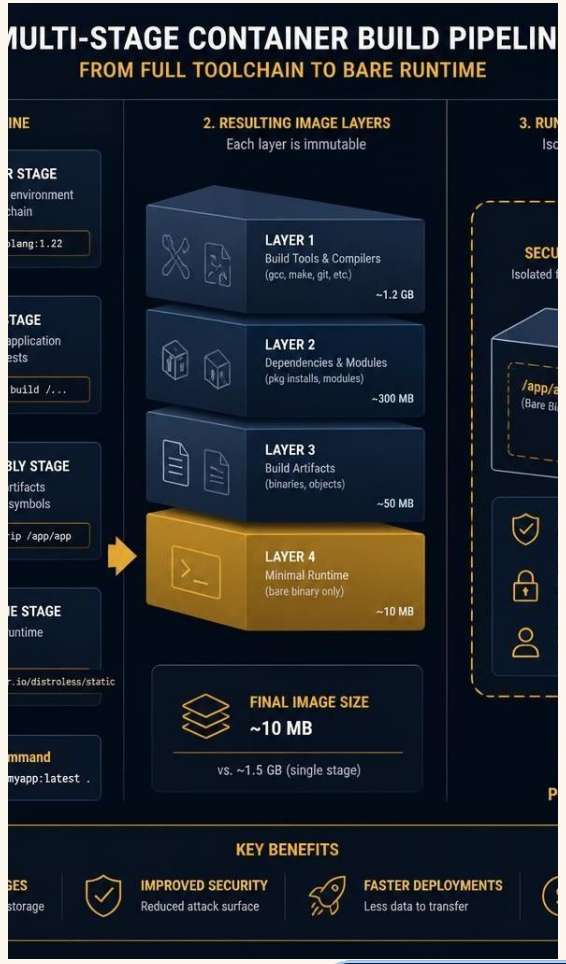
Ferramentas de CSPM ativas contra drift arquitetural, confrontando o ambiente com CIS Benchmarks e normas regulatórias em tempo real.

Configurações devem ser expressas como código (IaC) e validadas por analisadores de conformidade estática.

Made with GAMMA

Containers Docker: a segurança começa na imagem

- **Base images mínimas e fixadas por versão:** Alpine ou Distroless, pinned digests (SHA-256); evite `latest` e ferramentas de shell desnecessárias.
- **Execução sem root:** diretiva explícita `USER nonroot` impede escalada de privilégios para o host do container runtime.
- **Scan de vulnerabilidades e assinatura de imagens:** scanners de CVEs (Trivy, Grype) no pipeline e validação criptográfica de procedência via Cosign/Sigstore.
- **Sem segredos no Dockerfile:** credenciais segregadas por variáveis de runtime injetadas via KMS ou secrets managers externos.



Made with GAMMA

ORQUESTRAÇÃO

Cluster Defense

KUBERNETES

Kubernetes: controles em cada camada do cluster

A defesa do plano de controle e das cargas em execução opera em camadas concêntricas:

CAMADA 01

RBAC & Workload Identity

Desativação do token automático de ServiceAccount em pods padrão e concessão de papéis restritos por namespace sem permissões cluster-admin.

CAMADA 02

Isolamento de Rede

Imposição de NetworkPolicies com postura default-deny para tráfego leste-oeste, limitando movimentação lateral entre pods e serviços.

CAMADA 03

Pod Security Standards

Aplicação do perfil *Restricted*: bloqueio de containers privilegiados, hostPID, hostNetwork e exigência de filesystems somente-leitura.

CAMADA 04

Admission & Auditoria

Gatekeepers OPA/Kyverno para validação de manifests em tempo de deploy e auditoria centralizada de eventos da API do Kubernetes.

Princípio: o cluster deve assumir que qualquer pod comprometido tentará atingir o kube-apiserver e os metadados do host.

Made with GAMMA

SHIFT-LEFT

Static Analysis

SAST

Early Detection

SAST analisa o código antes de ele rodar

MOMENTO DE AÇÃO

Commit & Pull Request

Gatilho automático no branch de desenvolvimento. O feedback chega ao engenheiro em minutos, bloqueando o merge se houver vulnerabilidades graves.

Vantagem: menor custo de correção do ciclo de vida de software.

ALVOS DE DETECÇÃO

Padrões Sintáticos & Fluxo

Identificação de injeções SQL, XSS, deserialização insegura, caminhos vulneráveis de dados (taint analysis) e segredos acidentalmente commitados.

Desafio: calibrar regras para reduzir falsos positivos sem perder cobertura.

FERRAMENTAL MODERNO

Engenharia de Mercado

Semgrep: regras declarativas rápidas em AST.
SonarQube: qualidade, métricas e OWASP Top 10.
CodeQL: análise semântica avançada com queries de código como dados.

Integração: relatórios SARIF enviados ao painel de segurança.

SAST não substitui testes funcionais: ele examina o texto e a gramática do código, não o ambiente ativo.

Made with GAMMA

DYNAMIC TESTING

Black-box Analysis

DAST

DAST testa a aplicação em execução

Testes Dinâmicos (DAST)

Simula vetores de ataque reais a partir do exterior da aplicação rodando em ambiente de homologação ou staging isolado.

Visão Externa: análise black-box sem acesso ao código-fonte original.

Vulnerabilidades Reais: cabeçalhos HTTP incorretos, falhas de sessão, CORS permissivo e TLS fraco.

Ferramentas: OWASP ZAP (automação headless) e Burp Suite Enterprise (crawling avançado).

A Sinergia: SAST + DAST

Duas abordagens complementares que eliminam pontos cegos estruturais do pipeline de engenharia.

Cobertura Completa: SAST valida se o código é robusto; DAST valida se o ambiente e o deploy estão seguros.

Correlação IAST: sensores no runtime cruzam tráfego do DAST com linhas de código do SAST.

Redução de Falsos Positivos: o que o SAST aponta é validado pela explorabilidade real do DAST.

Regra de ouro: nunca execute DAST destrutivo diretamente em clusters de produção.

Runtime Testing

Made with GAMMA

AUTOMAÇÃO

CI/CD Pipeline

ESTEIRA

A esteira DevSecOps: segurança em cada etapa

Controles automatizados distribuídos de ponta a ponta do ciclo de entrega:

1

Commit

Secret Scanning com Gitleaks e **SAST** rápido em PR via Semgrep.

2

Build

SCA de dependências (Snyk) e scan de imagens Docker (Trivy).

3

Deploy

IaC Scan (Checkov) e verificação de políticas de admissão (OPA).

4

Runtime

DAST dinâmico, monitoramento e detecção via Falco/eBPF.

A esteira possui portões de qualidade (Quality Gates): quebras de build imediatas para vulnerabilidades de severidade Alta ou Crítica.

DevSecOps Flow

Made with GAMMA

TRABALHO PRÁTICO AVALIATIVO

Desafio Técnico Final

Projete uma arquitetura completa de esteira DevSecOps corporativa

ESCOPO DA ENTREGA

Desenho da esteira de CI/CD para microsserviços em nuvem com containers (AWS EKS, GKE ou AKS), detalhando cada ferramenta de checagem e critério de bloqueio.

MECANISMO DE DEFESA

Apresentação oral em equipes de 15 minutos perante banca de engenheiros de segurança convidados, justificando trade-offs e mitigação de falsos positivos.

CRITÉRIOS DE AVALIAÇÃO

Cobertura dos 4 estágios (Commit, Build, Deploy, Runtime), rigor nos limites de privilégios IAM/RBAC e automação com política de falha em código.

Prazo de submissão do repositório: 7 dias antes do seminário avaliativo.

Made with GAMMA